Relatório de Resposta a Incidente

10/11/2025

YR SECURITY

TLP:RED

Autor(a)	Data
Yasmin Gabrielle Rizzi Coutinho	10 de novembro de 2025

Este relatório foi desenvolvido para o curso **Incident Response Part 1 v2**, da **RSquad Academy**. O documento é baseado em um cenário de incidente fictício e simula a análise de um ataque de ransomware em um ambiente corporativo.

O conteúdo descreve as etapas de investigação, análise, contenção e recomendações de segurança, servindo exclusivamente como demonstração dos conhecimentos em resposta a incidentes.

SUMÁRIO

1. CONFIDENCIALIDADE 4
2. INTRODUÇÃO 4
3. CENÁRIO DE AMEAÇAS 4
4. TIMELINE DO INCIDENTE 5
5. DETALHES DO INCIDENTE 5
6. CYBER KILL CHAIN 15
6.1. RECONHECIMENTO (RECONNAISSANCE) 15
6.2. ARMAMENTO (WEAPONIZATION) 15
6.3. ENTREGA (DELIVERY) 15
6.4. EXPLORAÇÃO (EXPLOITATION) 15
6.5. INSTALAÇÃO (INSTALLATION) 15
6.6. COMANDO E CONTROLE (C2 - COMMAND AND CONTROL) 16
6.7. AÇÃO (ACTION) 16
7. ANÁLISE DE CAMPANHA 16
8. DIAMOND MODEL 17
9. CONTENÇÃO E RECOMENDAÇÕES 17
9.1. CONTENÇÃO 17
9.2. NOTIFICAÇÃO À ANPD 18
9.3. ENCARREGADO DE DADOS (DPO) 18
9.4. RECOMENDAÇÕES E MELHORIAS 19

1. CONFIDENCIALIDADE

Este documento, assim como quaisquer informações anexadas, possui natureza confidencial, sendo sua utilização restrita exclusivamente aos destinatários designados. É importante observar que diversos nomes de serviços e empresas mencionados neste documento são protegidos por direitos de marca registrada.

2. INTRODUÇÃO

O relatório a seguir tem como propósito analisar o incidente constatado em 05 de fevereiro de 2025, quando foi identificada a interrupção completa de sistemas críticos em decorrência de um ataque de ransomware. A investigação abrange as etapas de detecção, contenção e recuperação, com foco na análise das causas, impactos e nas medidas adotadas durante o processo de resposta.

O incidente provocou a indisponibilidade do sistema de ERP e o portal interno da empresa, resultando em paralisação das operações. Durante o processo inicial de resposta, a ausência de um plano formal e a tentativa imediata de restauração sem uma avaliação aprofundada contribuíram para a perda de informações e o prolongamento da indisponibilidade por aproximadamente 72 horas.

A análise a seguir visa registrar os principais eventos relacionados ao ataque e apontar as oportunidades de aprimoramento na infraestrutura e nos processos de segurança, de modo a reduzir o risco de recorrência e fortalecer a capacidade de resposta da organização diante de futuras ameaças.

3. CENÁRIO DE AMEAÇAS

A TSM é uma empresa de médio porte do setor de logística que opera com centros de distribuição físicos e uma plataforma de gestão online. Com filiais em diferentes regiões e alta dependência de seus sistemas internos, a empresa foi alvo de um ataque de ransomware no dia 05 de fevereiro de 2025, que resultou na indisponibilidade de servidores críticos e na criptografia de arquivos essenciais.

Durante a tentativa de restauração, notou-se que o servidor de backup também havia sido comprometido, impossibilitando a recuperação imediata dos dados e ampliando o impacto operacional. A ausência de controles de segurança adequados contribuiu para a severidade do ocorrido.

O episódio evidenciou as vulnerabilidades na infraestrutura de TI, destacando a necessidade de revisar as políticas internas, reforçar mecanismos de proteção e estabelecer práticas de gestão de incidentes e continuidade de negócios.

4. TIMELINE DO INCIDENTE

O incidente teve início em **11/09/2024**, com o recebimento de um e-mail de phishing contendo um anexo malicioso. Em **05/02/2025**, os servidores críticos ficaram indisponíveis e arquivos essenciais foram criptografados, comprometendo a operação dos sistemas. A restauração dos serviços ocorreu em **08/02/2025**, permitindo a retomada das atividades. A contenção do incidente teve início em **09/02/2025**, com a implementação de medidas para mitigar a propagação do ataque. Entre **09 e 17/02/2025**, a equipe realizou uma análise aprofundada dos artefatos obtidos, buscando determinar a origem do ataque e mensurar o impacto do incidente.

Figura 1: Timeline do incidente.

5. DETALHES DO INCIDENTE

Foi relatado o recebimento de um e-mail contendo anexo *.tar* no dia 11 de setembro de 2024 às 08:07 (UTC-3), alegando proposta comercial da Pars Paper Industrial Group Co (Figura 2).

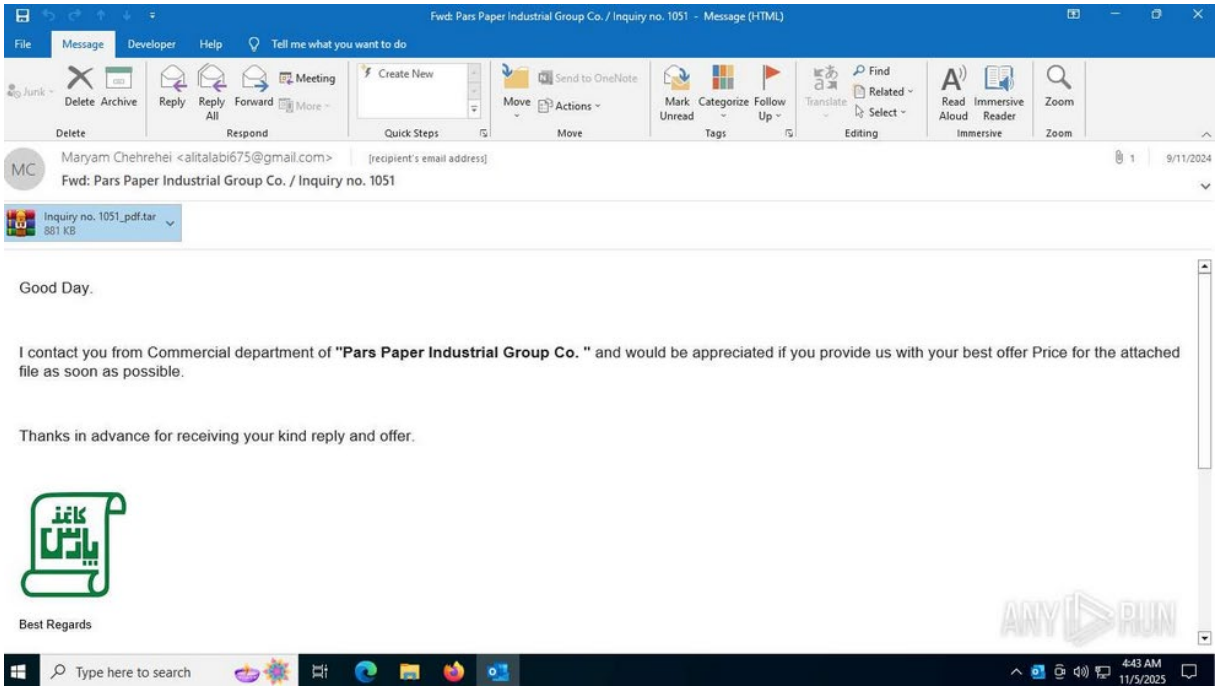


Figura 2: Conteúdo do e-mail.

O e-mail continha um link para um site iraniano legítimo (Figura 3), além de uma assinatura aparentemente verídica. No entanto, ao analisar seu cabeçalho foram reveladas falhas em SPF, DKIM e DMARC, vinculadas ao IP 155.94.211[.]8 (Figura 4), não autorizado a enviar mensagens pelo domínio *gmail.com*.

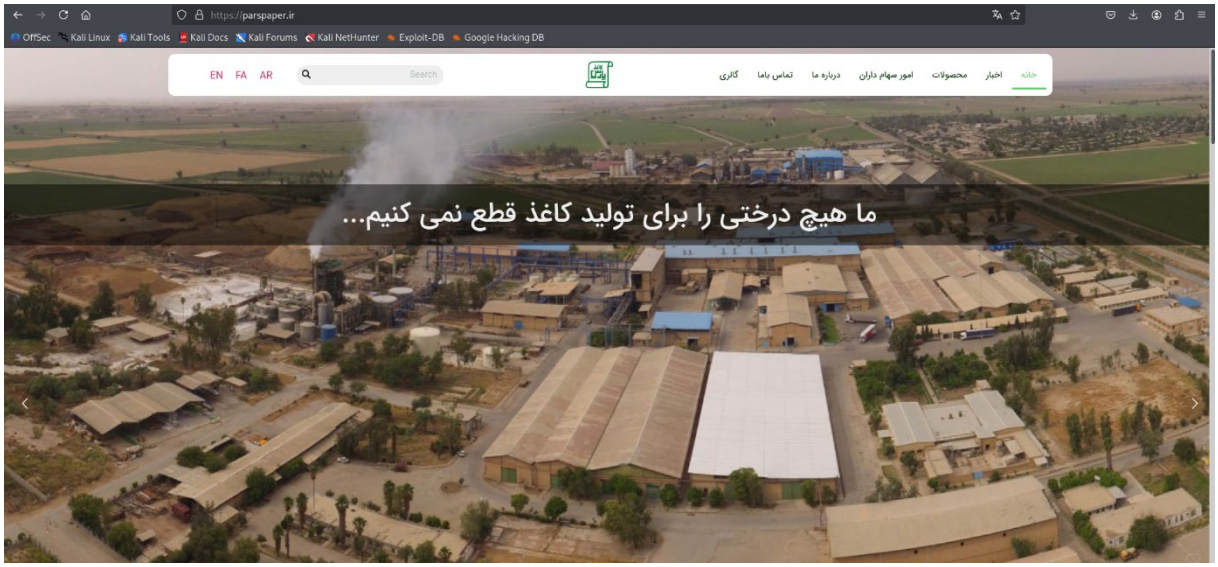


Figura 3: Site da empresa iraniana.

```
Return-Path: <alitalabi675@gmail.com>
Delivered-To: [recipient's email address]
Authentication-Results: [recipient's mail server]; dkim=none; dmarc=fail reason="No valid SPF, No valid DKIM" header.from=gmail.com (policy=none); spf=softfail (
[recipient's mail server]: 155.94.211.8 is neither permitted nor denied by domain of alitalabi675@gmail.com) smtp.mailfrom=alitalabi675@gmail.com
Received: from gmail.com (unknown [155.94.211.8])
    by [recipient's mail server] (Postfix) with ESMTP id [information removed]
    for <[recipient's email address]>; Wed, 11 Sep 2024 11:07:29 +0000 (UTC)
From: Maryam Chehrehei <alitalabi675@gmail.com>
To: [recipient's email address]
Subject: Fwd: Pars Paper Industrial Group Co. / Inquiry no. 1051
Date: 11 Sep 2024 04:07:26 -0700
Message-ID: <202409110140724.DA12B2F1EBBC70CE@gmail.com>
MIME-Version: 1.0
Content-Type: multipart/mixed;
    boundary="----=_NextPart_000_0012_22A314C7.70E3F348"

This is a multi-part message in MIME format.

------=_NextPart_000_0012_22A314C7.70E3F348
Content-Type: multipart/related;
    boundary="----=_NextPart_001_0013_22A314C7.70E3F348"


------=_NextPart_001_0013_22A314C7.70E3F348
Content-Type: text/html;
```

Figura 4: Cabeçalho do e-mail.

Após extrair e executar o arquivo anexado dentro de uma sandbox (Figura 5), notou-se requisições ao domínio *eadzagba1.duckdns*[.]*org* (Figura 6), associado a campanhas de phishing e malware (Figura 7). Além disso, **Remcos RAT** foi detectado (Figura 8), confirmando o caráter malicioso.

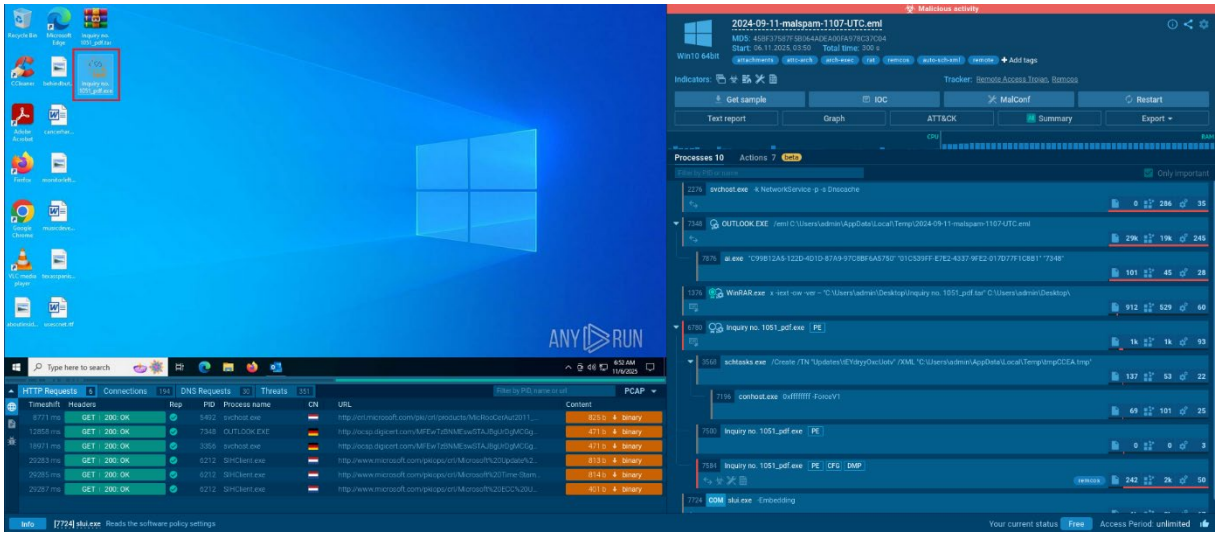


Figura 5: Execução de arquivo malicioso em sandbox.

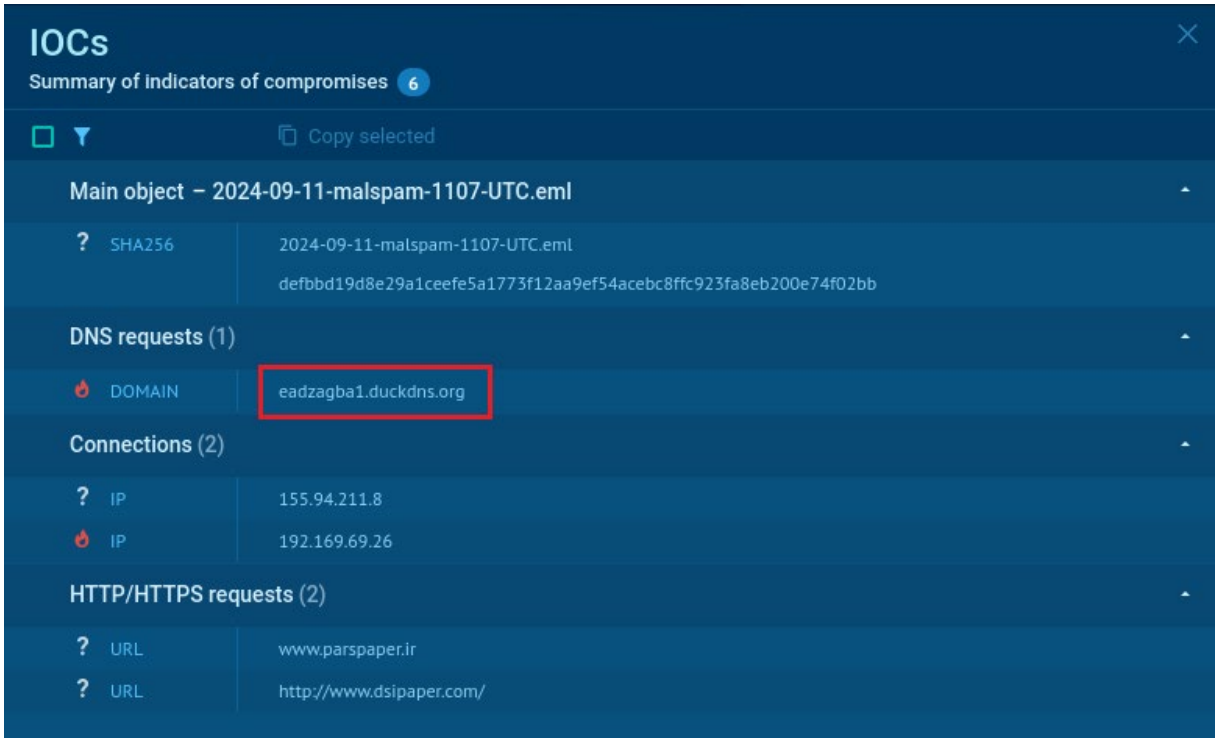


Figura 6: Requisição ao domínio *eadzagba1.duckdns[.]org*.

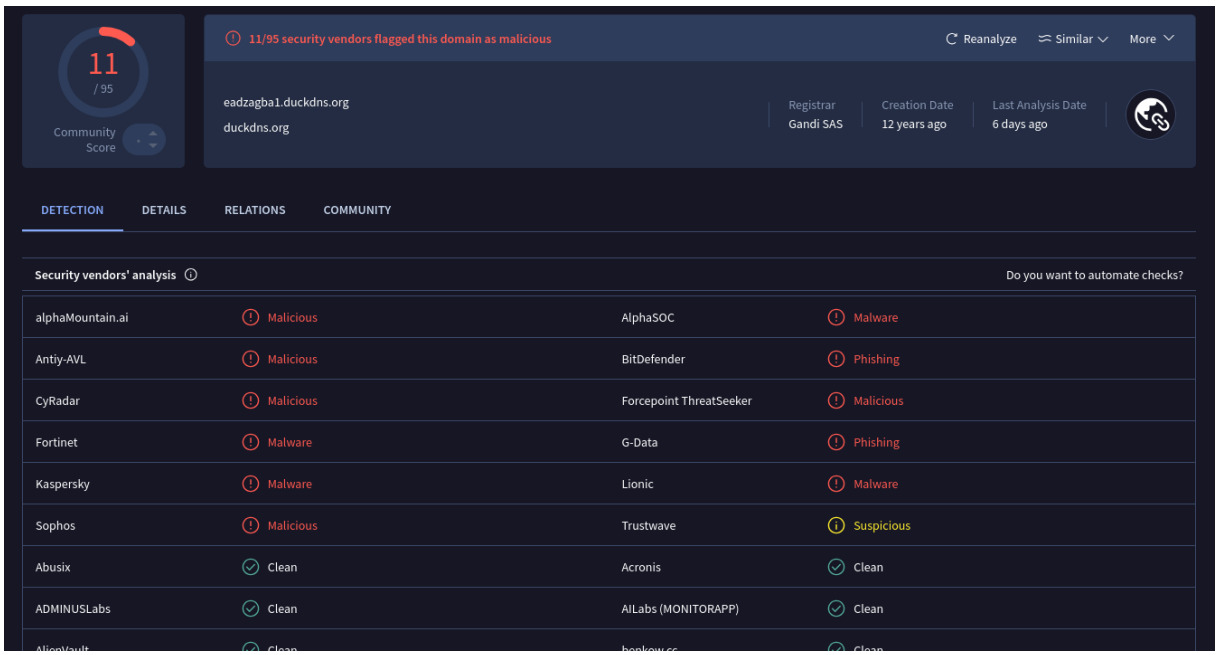


Figura 7: Reputação do domínio *eadzagba1.duckdns[.]org*.

Figura 8: Gráfico de processos do arquivo malicioso.

Ao obter a hash do arquivo malicioso e analisar sua reputação (Figura 9), nota-se associação ao grupo **Knight**, compatível com o pedido de resgate deixado no sistema da TSM (Figura 10).

Hash: dbf9cc65461c7bc650938156d3751d4ae0ce4312d3899f747e590767c0ef0408.

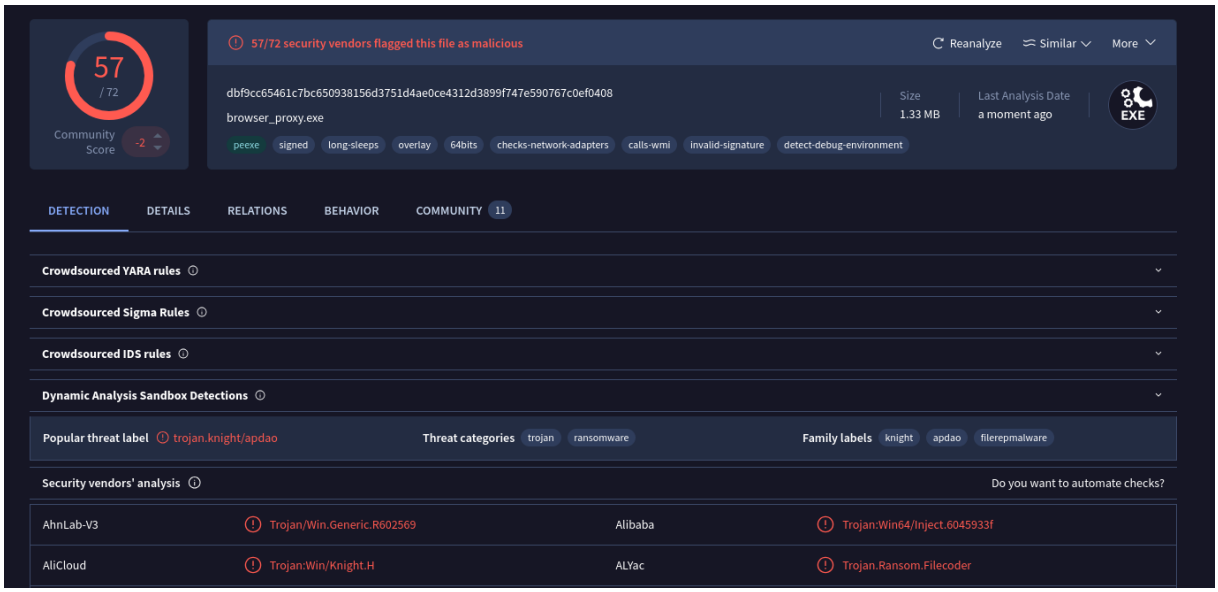
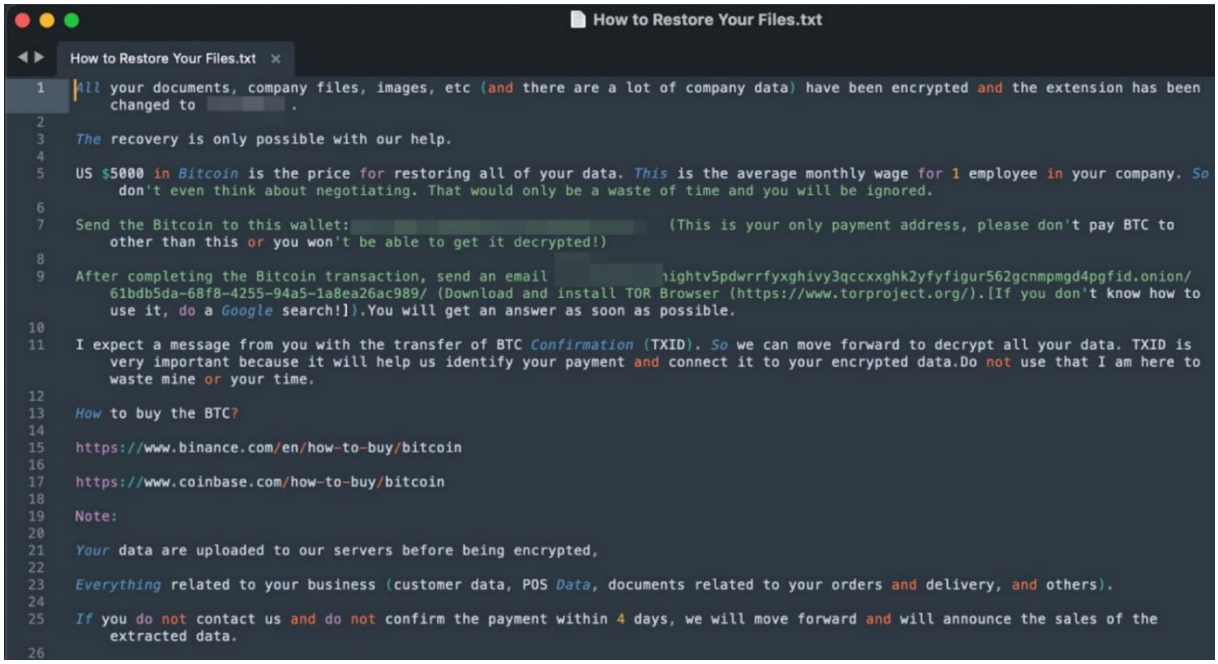


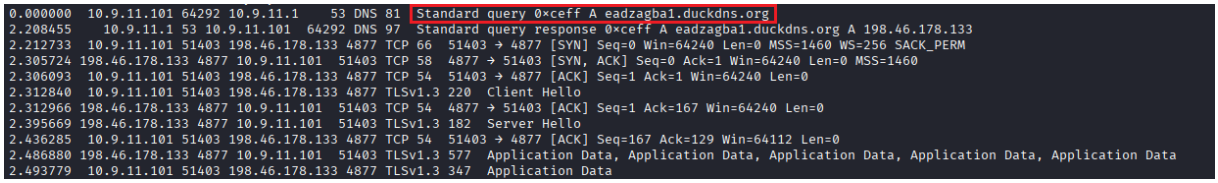
Figura 9: Reputação do arquivo malicioso


How to Restore Your Files.txt

```
All your documents, company files, images, etc (and there are a lot of company data) have been encrypted and the extension has been
    changed to [redacted] .

The recovery is only possible with our help.

US $5000 in Bitcoin is the price for restoring all of your data. This is the average monthly wage for 1 employee in your company. So
     don't even think about negotiating. That would only be a waste of time and you will be ignored.

Send the Bitcoin to this wallet:[redacted] (This is your only payment address, please don't pay BTC to
    other than this or you won't be able to get it decrypted!)

After completing the Bitcoin transaction, send an email [redacted]ightv5pdwrrfyxghivy3qccxxghk2yfyfigur562gcnmpmgd4pgfid.onion/
    61bdb5da-68f8-4255-94a5-1a8ea26ac989/ (Download and install TOR Browser (https://www.torproject.org/).[If you don't know how to
    use it, do a Google search!]).You will get an answer as soon as possible.

I expect a message from you with the transfer of BTC Confirmation (TXID). So we can move forward to decrypt all your data. TXID is
    very important because it will help us identify your payment and connect it to your encrypted data.Do not use that I am here to
    waste mine or your time.

How to buy the BTC?

https://www.binance.com/en/how-to-buy/bitcoin

https://www.coinbase.com/how-to-buy/bitcoin

Note:

Your data are uploaded to our servers before being encrypted,

Everything related to your business (customer data, POS Data, documents related to your orders and delivery, and others).

If you do not contact us and do not confirm the payment within 4 days, we will move forward and will announce the sales of the
    extracted data.
```

Figura 10: Pedido de resgate.

O tráfego malicioso na rede interna teve início em 11 de setembro, às 11h05 (UTC-3), quando o host 10.9.11.101 fez requisição ao domínio *eadzagba1.duckdns[.]org* (Figura 11).



0.000000	10.9.11.101	64292	10.9.11.1	53	DNS	81	Standard query 0×ceff A eadzagba1.duckdns.org	
2.208455	10.9.11.1	53	10.9.11.101	64292	DNS	97	Standard query response 0×ceff A eadzagba1.duckdns.org A 198.46.178.133	
2.212733	10.9.11.101	51403	198.46.178.133	4877	TCP	66	51403 → 4877 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM	
2.305724	198.46.178.133	4877	10.9.11.101	51403	TCP	58	4877 → 51403 [SYN, ACK] Seq=0 Ack=1 Win=64240 Len=0 MSS=1460	
2.306093	10.9.11.101	51403	198.46.178.133	4877	TCP	54	51403 → 4877 [ACK] Seq=1 Ack=1 Win=64240 Len=0	
2.312840	10.9.11.101	51403	198.46.178.133	4877	TLSv1.3	220	Client Hello	
2.312966	198.46.178.133	4877	10.9.11.101	51403	TCP	54	4877 → 51403 [ACK] Seq=1 Ack=167 Win=64240 Len=0	
2.395669	198.46.178.133	4877	10.9.11.101	51403	TLSv1.3	182	Server Hello	
2.436285	10.9.11.101	51403	198.46.178.133	4877	TCP	54	51403 → 4877 [ACK] Seq=167 Ack=129 Win=64112 Len=0	
2.486880	198.46.178.133	4877	10.9.11.101	51403	TLSv1.3	577	Application Data, Application Data, Application Data, Application Data, Application Data	
2.493779	10.9.11.101	51403	198.46.178.133	4877	TLSv1.3	347	Application Data	

Figura 11: Consulta do host ao domínio *eadzagba1.duckdns[.]org*.

O Duck DNS é um serviço gratuito de DNS dinâmico que permite associar domínios a endereços IP variáveis. Apesar de legítimo, é frequentemente utilizado por atacantes para mascarar a infraestrutura de comando e controle e dificultar sua identificação.

A relação temporal entre o recebimento do e-mail de phishing e o início das conexões com o domínio identificado indica que o e-mail malicioso atuou como vetor inicial do incidente, levando à execução do arquivo e à comunicação com a infraestrutura do atacante.

O domínio *eadzagba1.duckdns[.]org* resolve para o IP público 198.46.178[.]133, endereço pertencente a provedor nos Estados Unidos (AS36352 – HostPapa) (Figura 12), com o qual o host estabeleceu conexão TCP na porta 4877 (Figura 13), uma porta não padronizada utilizada para evasão de detecção. Após o estabelecimento da

sessão, foi observado o envio de dados do host para o servidor, seguido de resposta identificada como TLS (Figura 14), protocolo responsável por criptografar a comunicação entre as partes, possibilitando exfiltração sem visibilidade. A persistência dessa troca confirma a comunicação ativa com a infraestrutura de comando e controle.

ASN	AS36352 - HostPapa
Hostname	198-46-178-133-host.colocrossing.com
Range	198.46.178.0/24
Company	HostPapa
Hosted domains	0
Privacy	True
Anycast	False
ASN type	Hosting
Abuse contact	net-abuse-global@hostpapa.com

IP Geolocation

City	Buffalo
State	New York
Country	United States
Postal	14202
Local time	11:39 AM, Wednesday, November 05, 2025
Timezone	America/New_York
Coordinates	42.8865,-78.8784

42.8865,-78.8784

Figura 12: Identificação do IP 198.46.178[.]133.

```
0.000000  10.9.11.101 64292 10.9.11.1    53 DNS 81  Standard query 0×ceff A eadzagba1.duckdns.org
2.208455    10.9.11.1 53 10.9.11.101  64292 DNS 97  Standard query response 0×ceff A eadzagba1.duckdns.org A 198.46.178.133
2.212733  10.9.11.101 51403 198.46.178.133 4877 TCP 66  51403 → 4877 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM
2.305724 198.46.178.133 4877 10.9.11.101  51403 TCP 58  4877 → 51403 [SYN, ACK] Seq=0 Ack=1 Win=64240 Len=0 MSS=1460
2.306093  10.9.11.101 51403 198.46.178.133 4877 TCP 54  51403 → 4877 [ACK] Seq=1 Ack=1 Win=64240 Len=0
2.312840  10.9.11.101 51403 198.46.178.133 4877 TLSv1.3 220  Client Hello
2.312966 198.46.178.133 4877 10.9.11.101  51403 TCP 54  4877 → 51403 [ACK] Seq=1 Ack=167 Win=64240 Len=0
2.395669 198.46.178.133 4877 10.9.11.101  51403 TLSv1.3 182  Server Hello
2.436285  10.9.11.101 51403 198.46.178.133 4877 TCP 54  51403 → 4877 [ACK] Seq=167 Ack=129 Win=64112 Len=0
2.486880 198.46.178.133 4877 10.9.11.101  51403 TLSv1.3 577  Application Data, Application Data, Application Data, Application Data, Application Data
2.493779  10.9.11.101 51403 198.46.178.133 4877 TLSv1.3 347  Application Data
```

Figura 13: Handshake entre host interno e C2.

0.000000	10.9.11.101	64292	10.9.11.1	53	DNS	81	Standard query 0×ceff A eadzagba1.duckdns.org			
2.208455	10.9.11.1	53	10.9.11.101	64292	DNS	97	Standard query response 0×ceff A eadzagba1.duckdns.org A 198.46.178.133			
2.212733	10.9.11.101	51403	198.46.178.133	4877	TCP	66	51403 → 4877 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM			
2.305724	198.46.178.133	4877	10.9.11.101	51403	TCP	58	4877 → 51403 [SYN, ACK] Seq=0 Ack=1 Win=64240 Len=0 MSS=1460			
2.306093	10.9.11.101	51403	198.46.178.133	4877	TCP	54	51403 → 4877 [ACK] Seq=1 Ack=1 Win=64240 Len=0			
2.312840	10.9.11.101	51403	198.46.178.133	4877	TLSv1.3	220	Client Hello			
2.312966	198.46.178.133	4877	10.9.11.101	51403	TCP	54	4877 → 51403 [ACK] Seq=1 Ack=167 Win=64240 Len=0			
2.395669	198.46.178.133	4877	10.9.11.101	51403	TLSv1.3	182	Server Hello			
2.436285	10.9.11.101	51403	198.46.178.133	4877	TCP	54	51403 → 4877 [ACK] Seq=167 Ack=129 Win=64112 Len=0			
2.486880	198.46.178.133	4877	10.9.11.101	51403	TLSv1.3	577	Application Data, Application Data, Application Data, Application Data, Application Data			
2.493779	10.9.11.101	51403	198.46.178.133	4877	TLSv1.3	347	Application Data			

Figura 14: Protocolo TLS para criptografia da comunicação.

Em sequência, foi possível observar requisições ao domínio geoplugin[.]net (IP 178.237.33[.]50), incluindo a injeção de um arquivo *json.gp* (Figura 15). O comportamento está alinhado ao padrão de execução do **Remcos RAT**, que utiliza esse recurso para identificar a localização geográfica e IP público da vítima (Figura 16).

Time	Source	Src Port	Destination	Dst Port	Protocol	Length	Host	Info
2024-09-11 14:05:25.987033	198.46.178.133	4877	10.9.11.101	51403	TLSv1.3	88		Application Data
2024-09-11 14:05:26.035385	10.9.11.101	60069	10.9.11.1	53	DNS	73		Standard query 0xa46e A geoplugin.net
2024-09-11 14:05:26.042948	10.9.11.101	51403	198.46.178.133	4877	TCP	54		51403 → 4877 [ACK] Seq=1278 Ack=728 Win=63513 Len=0
2024-09-11 14:05:26.086903	10.9.11.1	53	10.9.11.101	60069	DNS	89		Standard query response 0xa46e A geoplugin.net A 178.237.33.50
2024-09-11 14:05:26.089961	10.9.11.101	51404	178.237.33.50	80	TCP	66		51404 → 80 [SYN] Seq=0 Win=65535 Len=0 MSS=1460 WS=256 SACK_PERM
2024-09-11 14:05:26.241662	178.237.33.50	80	10.9.11.101	51404	TCP	58		80 → 51404 [SYN, ACK] Seq=0 Ack=1 Win=64240 Len=0 MSS=1460
2024-09-11 14:05:26.242193	10.9.11.101	51404	178.237.33.50	80	TCP	54		51404 → 80 [ACK] Seq=1 Ack=1 Win=65535 Len=0
2024-09-11 14:05:26.243778	10.9.11.101	51404	178.237.33.50	80	HTTP	125	geoplugin.net	GET /json.gp HTTP/1.1
2024-09-11 14:05:26.244046	178.237.33.50	80	10.9.11.101	51404	TCP	54		80 → 51404 [ACK] Seq=1 Ack=72 Win=64240 Len=0
2024-09-11 14:05:26.406419	178.237.33.50	80	10.9.11.101	51404	HTTP/JSON	1216		HTTP/1.1 200 OK , JSON (application/json)
2024-09-11 14:05:26.406791	10.9.11.101	51404	178.237.33.50	80	TCP	54		51404 → 80 [ACK] Seq=72 Ack=1163 Win=65535 Len=0
2024-09-11 14:05:26.413671	10.9.11.101	51403	198.46.178.133	4877	TLSv1.3	1042		Application Data
2024-09-11 14:05:26.413854	198.46.178.133	4877	10.9.11.101	51403	TCP	54		4877 → 51403 [ACK] Seq=728 Ack=2266 Win=64240 Len=0
2024-09-11 14:05:27.401778	178.237.33.50	80	10.9.11.101	51404	TCP	54		80 → 51404 [FIN, PSH, ACK] Seq=1163 Ack=72 Win=64240 Len=0
2024-09-11 14:05:27.402143	10.9.11.101	51404	178.237.33.50	80	TCP	54		51404 → 80 [ACK] Seq=72 Ack=1164 Win=65535 Len=0
2024-09-11 14:05:49.429478	198.46.178.133	4877	10.9.11.101	51403	TLSv1.3	96		Application Data
2024-09-11 14:05:49.430977	10.9.11.101	51403	198.46.178.133	4877	TLSv1.3	115		Application Data
2024-09-11 14:05:49.431285	198.46.178.133	4877	10.9.11.101	51403	TCP	54		4877 → 51403 [ACK] Seq=770 Ack=2327 Win=64240 Len=0
2024-09-11 14:06:19.432434	198.46.178.133	4877	10.9.11.101	51403	TLSv1.3	96		Application Data
2024-09-11 14:06:19.434139	10.9.11.101	51403	198.46.178.133	4877	TLSv1.3	115		Application Data
2024-09-11 14:06:19.434417	198.46.178.133	4877	10.9.11.101	51403	TCP	54		4877 → 51403 [ACK] Seq=812 Ack=2388 Win=64240 Len=0
2024-09-11 14:06:49.435729	198.46.178.133	4877	10.9.11.101	51403	TLSv1.3	96		Application Data
2024-09-11 14:06:49.437026	10.9.11.101	51403	198.46.178.133	4877	TLSv1.3	116		Application Data
2024-09-11 14:06:49.437218	198.46.178.133	4877	10.9.11.101	51403	TCP	54		4877 → 51403 [ACK] Seq=854 Ack=2450 Win=64240 Len=0
2024-09-11 14:07:16.012921	10.9.11.101	51404	178.237.33.50	80	TCP	54		51404 → 80 [FIN, ACK] Seq=72 Ack=1164 Win=65535 Len=0
2024-09-11 14:07:16.013235	178.237.33.50	80	10.9.11.101	51404	TCP	54		80 → 51404 [ACK] Seq=1164 Ack=73 Win=64239 Len=0

Figura 15: Comunicação com geoplugin[.]net.

INTERNET ARCHIVE Wayback Machine http://geoplugin.net/json.gp

450 captures

9 Nov 2010 - 23 Sep 2025


```
{
  "geoplugin_request":"207.241.225.114",
  "geoplugin_status":206,
  "geoplugin_delay":"1ms",
  "geoplugin_credit":"Some of the returned data includes GeoLite2 data created by MaxMind, available from <a href='http:\/\/web.archive.org\/web\/20250401000540\/https:\/\/www.maxmind.com'>https:\/\/www.maxmind.com<\/a>.",
  "geoplugin_city":"",
  "geoplugin_region":"",
  "geoplugin_regionCode":"",
  "geoplugin_regionName":"",
  "geoplugin_areaCode":"",
  "geoplugin_dmaCode":"",
  "geoplugin_countryCode":"US",
  "geoplugin_countryName":"United States",
  "geoplugin_inEU":0,
  "geoplugin_euVATrate":false,
  "geoplugin_continentCode":"NA",
  "geoplugin_continentName":"North America",
  "geoplugin_latitude":"37.751",
  "geoplugin_longitude":"-97.822",
  "geoplugin_locationAccuracyRadius":"1000",
  "geoplugin_timezone":"America\/Chicago",
  "geoplugin_currencyCode":"USD",
  "geoplugin_currencySymbol":null,
  "geoplugin_currencySymbol_UTF8":"",
  "geoplugin_currencyConverter":0
}
```


Figura 16: Resposta JSON de geoplugin[.]net/json.gp.

A troca de pacotes entre o host interno e a infraestrutura de comando e controle manteve o mesmo padrão ao longo de todo o tráfego analisado.

Às 11h27 (UTC-3), observou-se o início de uma nova sessão entre o host 10.9.11.102 e o domínio *www.everycreation[.]shop* (IP 84.32.84[.]32). Este domínio é publicamente associado a servidores C2 para o malware **XLoader** (Figura 17).

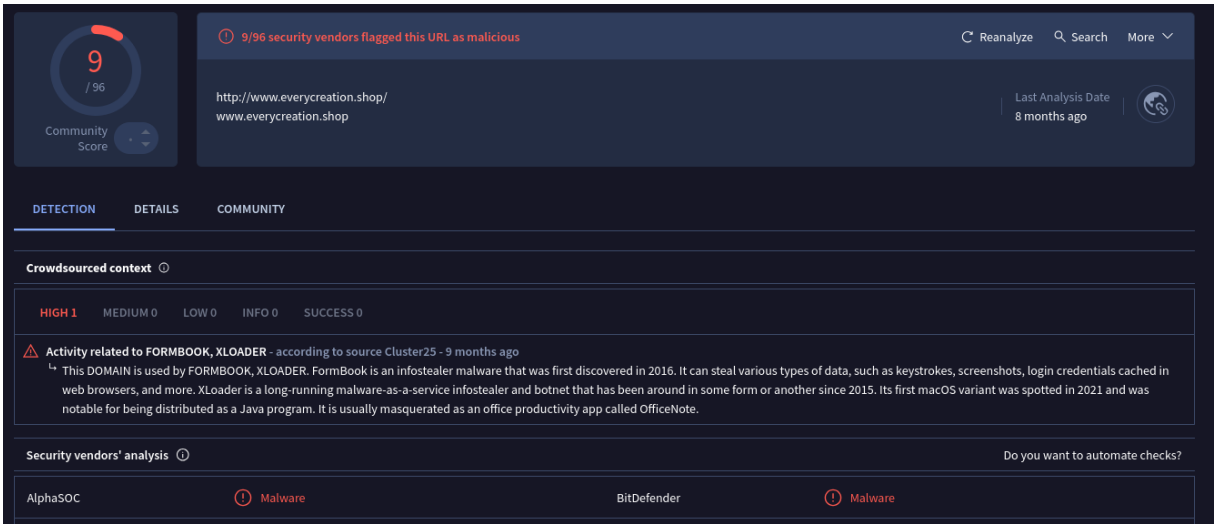
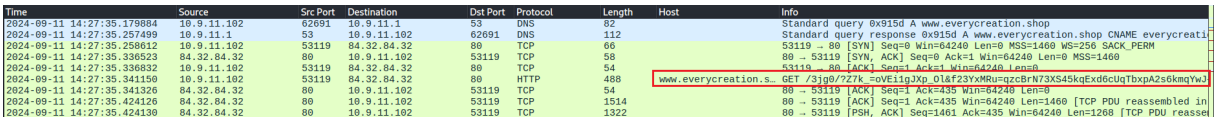


Figura 17: Reputação do domínio *www.everycreation[.]shop*.

Após o handshake inicial, o malware envia requisição *GET* com um caminho incomum (/3jg0/) e parâmetro longo e codificado (f23YxMRu=...) (Figura 18), que provavelmente contém informações iniciais sobre o host infectado.



Time	Source	Src Port	Destination	Dst Port	Protocol	Length	Host	Info
2024-09-11 14:27:35.179884	10.9.11.102	62691	10.9.11.1	53	DNS	82		Standard query 0x915d A www.everycreation.shop
2024-09-11 14:27:35.257499	10.9.11.1	53	10.9.11.102	62691	DNS	112		Standard query response 0x915d A www.everycreation.shop CNAME everycreati
2024-09-11 14:27:35.258612	10.9.11.102	53119	84.32.84.32	80	TCP	66		53119 → 80 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM
2024-09-11 14:27:35.336523	84.32.84.32	80	10.9.11.102	53119	TCP	58		80 → 53119 [SYN, ACK] Seq=0 Ack=1 Win=64240 Len=0 MSS=1460
2024-09-11 14:27:35.336832	10.9.11.102	53119	84.32.84.32	80	TCP	54		53119 → 80 [ACK] Seq=1 Ack=1 Win=64240 Len=0
2024-09-11 14:27:35.341150	10.9.11.102	53119	84.32.84.32	80	HTTP	488	www.everycreation.s…	GET /3jg0/?Z7k_=oVEi1gJXp_Ol&f23YxMRu=qzcBrN73XS45kqExd6cUqTbxpA2s6kmqYwJ
2024-09-11 14:27:35.341326	84.32.84.32	80	10.9.11.102	53119	TCP	54		80 → 53119 [ACK] Seq=1 Ack=435 Win=64240 Len=0
2024-09-11 14:27:35.424126	84.32.84.32	80	10.9.11.102	53119	TCP	1514		80 → 53119 [ACK] Seq=1 Ack=435 Win=64240 Len=1460 [TCP PDU reassembled in
2024-09-11 14:27:35.424130	84.32.84.32	80	10.9.11.102	53119	TCP	1322		80 → 53119 [PSH, ACK] Seq=1461 Ack=435 Win=64240 Len=1268 [TCP PDU reasse

Figura 18: Requisição *GET*.

Em seguida, passa a se comunicar com *www.chalet-tofane[.]net* (IP 62.149.128[.]40), que faz uma requisição *POST* contendo um grande volume de dados (4641 bytes) sob o mesmo parâmetro codificado (f23YxMRu=...) (Figura 19). Isso é um forte indício de exfiltração de dados ou o upload de uma resposta grande a um comando do C2.

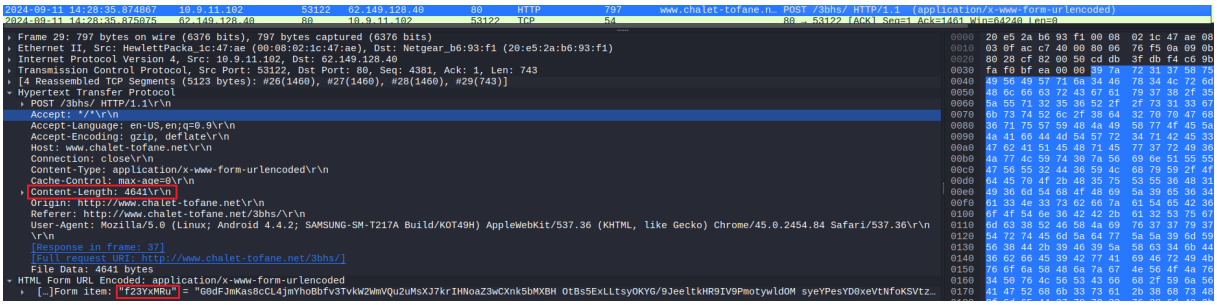


Figura 19: Requisição *POST*.

Foi observada uma comunicação contínua e persistente com diferentes domínios (Tabela 1), todos também associados ao **XLoader**. Este comportamento é típico de

infraestruturas de comando e controle, nas quais se busca estabelecer conexão redundante com o host infectado.

Domínio	IP
www.allthingsjasmin[.]com	3.33.130[.]190, 15.197.148[.]33
www.chalet-tofane[.]net	62.149.128[.]40
www.d27dm[.]top	154.23.184[.]141
www.federall[.]store	45.130.41[.]13
www.inf30027group23[.]xyz	221.121.144[.]149
www.kabaribukota[.]press	203.175.9[.]138
www.lojashelp[.]video	15.197.148[.]33, 3.33.130[.]190
www.mechecker[.]life	162.0.238[.]43
www.platinumkitchens[.]info	3.33.130[.]190, 15.197.148[.]33
www.rockbull[.]pro	185.174.173[.]22
www.rtpgaruda888resmi[.]xyz	198.252.106[.]136
www.sansensors[.]info	15.197.148[.]33, 3.33.130[.]190
www.trisixnine[.]net	195.110.124[.]133
www.useanecdotenow[.]tech	15.197.148[.]33, 3.33.130[.]190
www.weatherbook[.]live	15.197.148[.]33, 3.33.130[.]190

Tabela 1: Infraestrutura C2 do Xloader.

Apesar dos hosts infectados estarem na mesma infraestrutura e da proximidade temporal entre os tráfegos analisados, observa-se um padrão distinto no segundo, caracterizado pela comunicação com múltiplos destinos e pela ausência de criptografia. Assim, conclui-se que os eventos não estão relacionados, tratando-se de outro incidente para o qual não há informações suficientes que permitam determinar o vetor de ataque.

6. CYBER KILL CHAIN

A análise do incidente ocorrido na TSM permite compreender o encadeamento lógico das ações do adversário a partir das etapas definidas no modelo *Cyber Kill Chain*. Essa abordagem possibilita visualizar a progressão da intrusão e os pontos em que a defesa poderia ter interrompido o ataque.

6.1. RECONHECIMENTO (RECONNAISSANCE)

Os indícios apontam que os invasores realizaram uma coleta prévia de informações sobre a TSM antes de executar o ataque. O conteúdo e o formato do e-mail de phishing sugerem que houve reconhecimento do ambiente corporativo e do padrão de comunicação da empresa. A mensagem fazia uso de elementos visuais legítimos, o que indica um esforço deliberado para enganar o destinatário e aumentar a probabilidade de sucesso.

6.2. ARMAMENTO (WEAPONIZATION)

Nesta etapa, os agentes de ameaça prepararam o artefato malicioso responsável por viabilizar o acesso inicial. O anexo encaminhado no e-mail continha um executável associado ao **Remcos RAT**. Esse software é amplamente utilizado em campanhas de acesso remoto e espionagem e foi configurado para estabelecer conexão com servidores externos, permitindo controle total do sistema comprometido.

6.3. ENTREGA (DELIVERY)

O vetor de entrega foi o próprio e-mail de phishing recebido em 11 de setembro de 2024. A mensagem simulava uma proposta comercial legítima, utilizando o domínio de uma empresa real para mascarar sua origem. O acesso ao arquivo anexado e sua posterior execução permitiram a instalação do código malicioso, dando início à infecção dentro da rede da TSM.

6.4. EXPLORAÇÃO (EXPLOITATION)

O código malicioso explorou permissões locais e fragilidades no sistema, como a ausência de um mecanismo de detecção e resposta (EDR). Essa exploração permitiu ao atacante obter persistência e executar comandos remotamente, possibilitando coleta de informações e possível movimentação lateral dentro da infraestrutura corporativa.

6.5. INSTALAÇÃO (INSTALLATION)

Com a infecção consolidada, o **Remcos RAT** foi instalado e configurado para permanecer ativo mesmo após reinicializações do sistema. Em seguida, iniciou

comunicações com o domínio *eadzagba1.duckdns[.]org*, identificado como parte da infraestrutura de comando e controle. Essa persistência garantiu aos invasores o controle contínuo do host e a possibilidade de realizar novas descargas de malware, preparando o ambiente para a etapa seguinte do ataque.

6.6. COMANDO E CONTROLE (C2 - COMMAND AND CONTROL)

O host comprometido passou a manter comunicação constante com o servidor C2, hospedado nos Estados Unidos e associado ao IP 198.46.178[.]133. Essa troca de informações ocorreu por meio de sessões TLS em portas não convencionais, com o objetivo de dificultar a detecção pelos mecanismos de segurança. O uso de serviços de DNS dinâmico, como o Duck DNS, contribuiu para mascarar a real infraestrutura do atacante e aumentar a resiliência da comunicação entre as partes.

6.7. AÇÃO (ACTION)

Na etapa final, o grupo **Knight** executou ações típicas de dupla extorsão, realizando a exfiltração de dados sensíveis e, em seguida, a criptografia de arquivos em servidores críticos. O servidor de backup também foi comprometido, inviabilizando a restauração imediata. As atividades confirmam o objetivo do grupo de causar impacto operacional e obter vantagem financeira por meio da exposição e sequestro das informações. A TSM permaneceu sem acesso aos sistemas por aproximadamente 72 horas, com prejuízo direto às operações.

7. ANÁLISE DE CAMPANHA

O grupo **Knight**, anteriormente conhecido como Cyclops, surgiu em 2023 e atua no modelo Ransomware-as-a-Service (RaaS), fornecendo tanto o módulo de criptografia quanto ferramentas de exfiltração de dados. Desde então, tem conduzido campanhas direcionadas a diversos setores, incluindo o de logística e distribuição, que se mostra especialmente vulnerável devido à alta dependência de sistemas integrados e à criticidade operacional.

Os ataques seguem o modelo de dupla extorsão, no qual os dados são exfiltrados antes da criptografia. Caso o resgate não seja pago, as informações são publicadas em um site mantido pelo grupo, ampliando o impacto e a pressão sobre as vítimas.

O acesso inicial costuma ocorrer por meio de phishing, exploração de aplicações expostas ou uso de credenciais comprometidas. Após o comprometimento, os operadores realizam movimentação lateral, coleta de credenciais e execução do payload responsável pela criptografia dos arquivos.

Em termos técnicos, o **Knight** emprega criptografia moderna e canais de comunicação cifrada com a infraestrutura de comando e controle, utilizando serviços legítimos e DNS dinâmico para dificultar a detecção pelas defesas convencionais.

8. DIAMOND MODEL

O Diamond Model permite mapear as relações entre os elementos centrais de um incidente, como adversário, capacidade, infraestrutura e vítima (Figura 20). Cada elemento é representado como um vértice conectado, o que facilita a análise detalhada da intrusão.

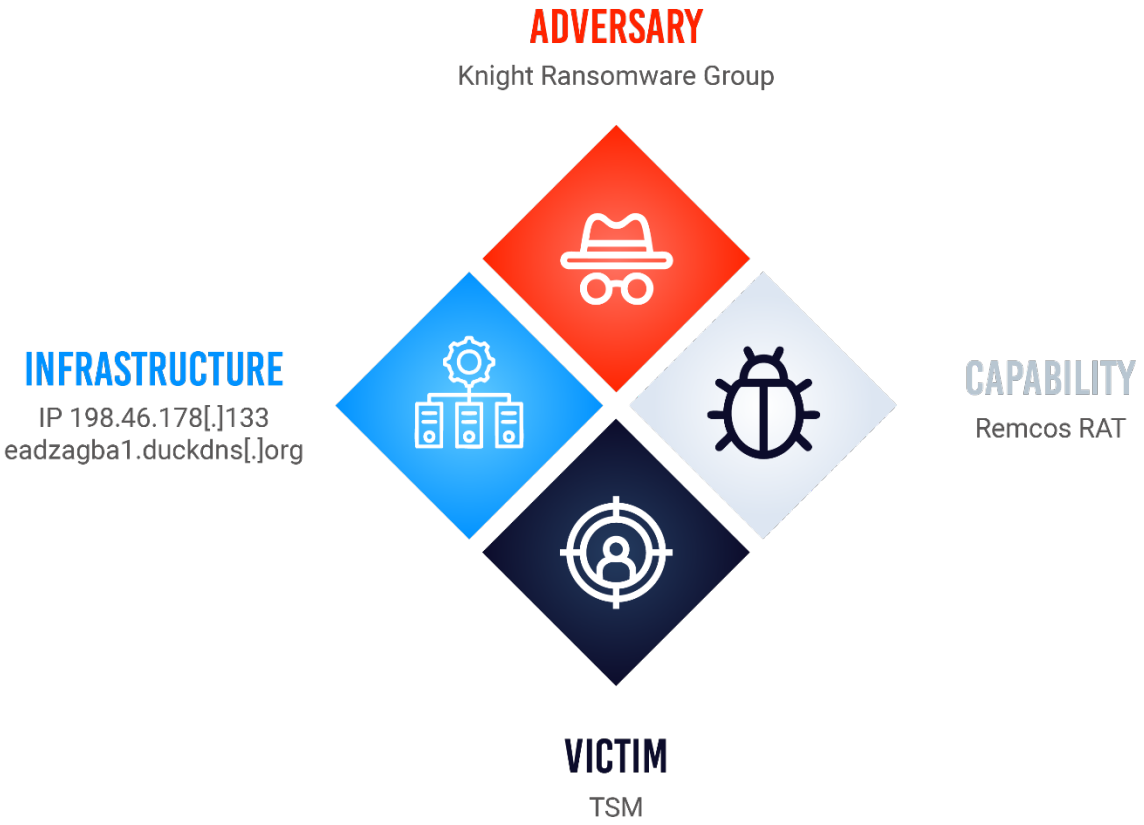


Figura 20: Diamond Model.

9. CONTENÇÃO E RECOMENDAÇÕES

9.1. CONTENÇÃO

Após a identificação do e-mail de phishing responsável pelo comprometimento inicial, foram adotadas medidas imediatas para conter o incidente e evitar novos impactos.

Os hosts afetados foram isolados da rede, interrompendo a comunicação com o C2, e regras de bloqueio foram aplicadas no firewall para os domínios e endereços IP identificados. Adicionalmente, foi realizada a redefinição forçada das senhas de todas as contas administrativas e de serviço do Active Directory para neutralizar os riscos envolvendo qualquer credencial que possa ter sido obtida.

A **YR Security** realizou uma varredura completa no ambiente, removendo artefatos identificados como trojan e infostealer. Os sistemas restaurados a partir de backup foram reavaliados antes da reintegração, garantindo que não houvesse resquícios de código malicioso.

Além disso, foram aplicadas atualizações de segurança e criadas GPOs para impedir modificações não autorizadas nos diretórios de aplicações sensíveis.

9.2. NOTIFICAÇÃO À ANPD

Considerando a possibilidade de vazamento de dados pessoais de clientes e colaboradores, recomenda-se que a TSM notifique a Autoridade Nacional de Proteção de Dados (ANPD) em até 72 horas após a confirmação do incidente, conforme previsto na LGPD.

A notificação deve incluir:

- **Descrição do incidente:** apresentar a data, origem, sistemas afetados e as ações adotadas para mitigação.
- **Dados pessoais comprometidos:** especificar os tipos de dados potencialmente expostos e a natureza dessas informações.
- **Medidas adotadas:** escrever as ações de contenção executadas.
- **Avaliação de impacto:** identificar as consequências da exposição de dados corporativos e pessoais para os titulares.
- **Plano de mitigação:** detalhar medidas tomadas para prevenir novos incidentes.

9.3. ENCARREGADO DE DADOS (DPO)

Recomenda-se a nomeação de um DPO (Encarregado de Proteção de Dados Pessoais) para assegurar conformidade contínua com a LGPD e aprimorar a governança de dados da TSM.

Entre suas atribuições:

- Monitorar a conformidade legal no tratamento de dados pessoais;
- Coordenar comunicações com a ANPD em incidentes futuros;

- Promover treinamentos periódicos e ações de conscientização;
- Apoiar na implementação de controles de segurança e políticas de privacidade.

9.4. RECOMENDAÇÕES E MELHORIAS

9.4.1. Política de backup

Implementar uma política de backup que garanta cópias regulares, armazenadas em ambiente isolado e protegido contra alterações não autorizadas. Os backups devem ser testados periodicamente para garantir a possibilidade de restauração completa em caso de incidente.

9.4.2. Soluções EDR/XDR

Substituir o antivírus atual por uma solução EDR ou XDR, capaz de detectar atividades anômalas e movimentação lateral. Essa ferramenta deve integrar alertas centralizados, permitindo resposta rápida e direcionada.

9.4.3. Revisão do firewall

Revisar as regras do firewall para garantir que apenas portas e protocolos essenciais permaneçam autorizados e manter o monitoramento contínuo para identificar tráfego suspeito.

9.4.4. Segmentação de rede e DMZ

Segmentar a rede isolando servidores essenciais, como o Active Directory e o de backup. Serviços expostos, como o servidor web Nginx, devem operar em DMZ com controle de acesso restrito, minimizando o risco de propagação de ataques.

9.4.5. Proteção de e-mail

Reforçar a segurança do Zimbra Collaboration com autenticação multifator (MFA), autenticação de remetentes e filtros anti-phishing. Implementar sandboxing para análise de anexos suspeitos e bloqueio de links maliciosos.

9.4.6. Conscientização e treinamento

Realizar treinamentos periódicos voltados à identificação de phishing, engenharia social e boas práticas de segurança. O conteúdo deve ser prático e alinhado às ameaças observadas no ambiente corporativo.

9.4.7. Gestão de vulnerabilidades

Implementar uma rotina de varredura com ferramentas como OpenVAS ou Nessus, priorizando correção de vulnerabilidades críticas e permissões excessivas. Os relatórios devem orientar as ações corretivas e permitir rastrear vulnerabilidades reincidentes.

9.4.8. Atualização de sistemas

Substituir sistemas fora de suporte, como o Ubuntu 18.04, e manter servidores e aplicações atualizados conforme cronograma controlado, priorizando patches críticos e versões estáveis.

9.4.9. Monitoramento contínuo

Integrar logs de firewall, servidores e endpoints a uma solução SIEM, ampliando a visibilidade sobre eventos de autenticação, tentativas de acesso privilegiado e comunicações externas fora do padrão.

9.4.10. Plano de resposta a incidentes

Formalizar um plano de resposta a incidentes com fluxos definidos de contenção, erradicação e recuperação. O documento deve ser revisado regularmente e atualizado conforme a evolução das ameaças e mudanças na infraestrutura.